

PART 8 OF 18

Memory Governance for Enterprise AI

Memory Lifecycle Management, Classification, Access Control, Integrity, Retention Policies, Poisoning Detection, and Regulatory Compliance

ENTERPRISE AI CONTROL ARCHITECTURE

Implementation Guide for Production AI Systems • 2026

8.1 Memory as a Regulated Enterprise Asset

Agent memory is not merely a technical implementation detail—it is a regulated enterprise asset with legal, compliance, and security implications that match or exceed those of traditional data stores. Memory systems contain: user personal data (GDPR/CCPA scope), business decision context (SOX/financial regulations scope), confidential business information (IP and trade secret scope), and potentially privileged communications (legal privilege considerations). Treating memory as an afterthought is a critical enterprise risk.

Regulatory Reality Check: Under GDPR Article 17 (Right to Erasure), if an agent's episodic memory contains PII about a data subject, that subject can demand deletion of that memory. This requires memory systems to support granular, attributable deletion capabilities—not just bulk purge. Memory governance is therefore a legal requirement, not merely a security best practice.

8.2 Memory Type Taxonomy

8.2.1 Working Memory

Working memory is the agent's active context window—the information in scope for the current reasoning step. It is ephemeral by nature, existing only for the duration of an inference call. However, working memory is the primary vector for prompt injection because it directly influences model outputs. Governance focuses on controlling what enters working memory from external sources.

Working Memory Controls

- Content classification: all items entering working memory tagged with trust level and data classification
- Size limits: enforce maximum context size to prevent context flooding attacks
- Content filtering: scan for injection patterns before inclusion in working memory
- Source attribution: every item in context tagged with its origin for audit purposes
- Sensitive data masking: PII and secrets detected and masked before entering model context

8.2.2 Long-Term Memory Systems

Type	Content	Storage	Scope	Access Control	Retention
Episodic Memory	Records of specific past interactions and events	Vector DB + structured metadata	Agent instance	ABAC by agent instance + data classification	90 days default; configurable
Semantic Memory	Factual knowledge and learned concepts	Vector DB (dedicated namespace)	Agent type	Agent type read; human write only	Aligned with knowledge validity period
Procedural Memory	How-to knowledge, workflows, learned strategies	Structured DB with versioning	Agent type	Agent type read; ops team write	Version-controlled; indefinite

Type	Content	Storage	Scope	Access Control	Retention
Organizational Memory	Shared enterprise knowledge across agents	Enterprise knowledge graph	Organization	Strict ABAC by data classification	Indefinite with periodic review
User Context Memory	Preferences and history for individual users	Encrypted user-scoped store	User-session	User consent required; strict access	User-defined or regulatory max

8.3 Memory Access Control Architecture

8.3.1 Memory Authorization Model

Memory access control must be enforced by a Memory Governor—a dedicated service that intermediates all memory reads and writes. The agent never accesses memory directly; all memory operations go through the Governor, which applies ABAC policies based on the agent's identity, task scope, and the classification of the memory content.

Operation	Authorization Required	Additional Controls
Read working memory	Task identity token	None (ephemeral)
Read own session memory	Session identity token matching memory's session ID	Anomaly alert if reading old sessions
Read own episodic memory	Agent type identity + data classification check	Rate limiting; audit log
Read org shared memory	Agent type identity + ABAC policy evaluation	Data classification enforcement; audit
Write session memory	Session identity token	Content scanning before write
Write episodic memory	Agent type identity + content safety check	Human approval for sensitive content
Write org shared memory	Human principal approval required	Content review workflow; versioning
Delete any memory	Human approval + compliance check	Retention policy verification; audit trail

8.4 Memory Integrity and Provenance

8.4.1 Content Integrity Verification

Memory content can be tampered with at rest (database compromise), in transit (MITM), or through authorized but malicious writes (memory poisoning by compromised agent). Integrity verification must detect all three attack vectors.

- **Write-time Hashing:** SHA-256 hash of each memory entry computed and stored alongside content; any modification invalidates hash
- **Merkle Tree Integrity:** Memory collections organized in Merkle trees; single hash covers entire collection; efficient tamper detection
- **Digital Signatures:** Sensitive memory entries signed by the agent's private key at write time; signature verifiable by any reader
- **Read-time Verification:** Memory Governor verifies hash/signature on every read; tampered entries returned as null with alert
- **Provenance Chain:** Each memory entry carries: writing agent identity, delegating human identity, task ID, timestamp, and parent memory ID if derived

8.4.2 Memory Poisoning Detection

Memory poisoning detection operates at write time, retrieval time, and through periodic batch analysis. Write-time detection prevents obviously malicious content from entering memory. Retrieval-time detection identifies poisoned content before it influences the agent. Batch analysis detects slow, gradual poisoning campaigns that evade per-write detection.

Detection Layer	Method	Timing	Latency
Write-time semantic scan	Classify content for injection patterns, factual anomalies	Synchronous pre-write	50-200ms
Write-time drift check	Compare against existing memory distribution; flag outliers	Synchronous pre-write	100ms
Retrieval-time consistency	Verify retrieved content is consistent with cross-references	Synchronous on retrieval	20-100ms
Batch statistical analysis	Analyze memory corpus for coordinated poisoning campaigns	Async daily/weekly batch	Hours
Ground truth comparison	Periodically verify memory facts against authoritative sources	Async weekly	Hours
Agent behavior correlation	Correlate memory content changes with agent behavior changes	Async real-time	Minutes

8.5 Memory Lifecycle and Retention

8.5.1 Memory Lifecycle Stages

Stage: Creation

Memory entry written; hash computed; provenance recorded; classification assigned

Stage: Active Use

Entry retrieved and used in agent context; access logged; integrity verified on each access

Stage: Review

Periodic content review for accuracy, relevance, and compliance; human review for sensitive entries

Stage: Archival

Entries past active use period moved to cold storage; retrieval still possible but slower

Stage: Deletion

Cryptographic deletion (key rotation) for sensitive entries; standard deletion for others; audit record preserved

8.5.2 Regulatory Retention Mapping

Regulation	Scope	Retention Requirement	Memory Implication
GDPR (EU)	EU personal data	Minimum necessary duration; Right to Erasure	PII memory must be attributable and deletable per data subject
CCPA/CPRA (California)	California resident PII	Right to delete; data minimization	Same as GDPR; US state law additive
SOX (US)	Financial records	7 years minimum	Financial decision context memory retained 7 years in immutable store
HIPAA (US)	Health information	6 years from creation	Any PHI in agent memory subject to HIPAA retention and security rules
ISO 27001	Business records	Organization-defined	Memory retention policy must be documented and audited
EU AI Act	High-risk AI decisions	Defined per risk category	Decision context and reasoning traces for high-risk agents must be retained